

HO CHI MINH UNIVERSITY OF SCIENCE

FACULTY OF INFORMATION TECHNOLOGY

DATA SECURITY IN INFORMATION SYSTEMS



THEORY REPORT

CHAPTER 8: MALWARE

LECTURER:

Phạm Thị Bạch Huệ - Lương Văn Minh

STUDENT (GROUP 7):

Đỗ Quang Minh Triết - 23127131

Đinh Đại Vũ - 23127144

Lê Phạm Kiều Duyên - 23127184

Lê Trương Bảo Ngọc - 23127237

Nguyễn Đăng Phôn - 23127451

Contents

1	Introduction and Scope of Research	7
1.1	Alignment with the CIA Triad	7
1.2	Scope of Research	7
2	Classification and Architecture of Malicious Software	9
2.1	Overview	9
2.2	Classification	9
2.2.1	Viruses	9
2.2.2	Worms	10
2.2.3	Trojan Horses	12
2.2.4	Logic Bombs	13
2.2.5	Spyware	13
2.2.6	Adware	15
2.2.7	Botnets	16
2.2.8	Keystroke Loggers	17
2.2.9	Malicious Add-Ons (Browser Extensions)	17
3	Vulnerabilities and Malware Enablers	19
3.1	Active Content Vulnerabilities	19
3.2	Homepage Hijacking	19
3.3	Webpage Defacements	20
4	Attack Vectors	22
4.1	Social Engineering and Phishing	22
4.2	Spam-Based Attacks	22
4.3	Software Vulnerability Exploitation	22
4.4	Denial of Service (DoS/DDoS)	23
5	Anatomy of an Attack	24
5.1	What Motivates Attackers?	24
5.2	The Purpose of an Attack	25
5.3	Types of Attacks	26
5.3.1	Unstructured Attacks	26
5.3.2	Structured attacks	26
5.3.3	Direct Attacks	27
5.3.4	Indirect Attacks	27
5.4	Phases of an Attack	28
5.4.1	Reconnaissance and Probing	28
5.4.2	Access and Privilege Escalation	28
5.4.3	Covering Traces of the Attack	28
6	Case Study: The MGM Resorts Cyberattack (September 2023)	30
6.1	Background and Context	30
6.2	The Two Threat Actors	30
6.3	Phase 1 — Reconnaissance and Probing	31
6.3.1	The Intelligence Gathering	31

6.3.2	Why This Phase Is the Most Critical	31
6.4	Access and Privilege Escalation	31
6.4.1	The Entry Point: Okta	31
6.4.2	Lateral Movement: From Cloud to Physical Operations	32
6.4.3	Data Exfiltration: The Double-Extortion Setup	32
6.4.4	The Ransomware Deployment	33
6.5	Phase 3 — Covering Traces of the Attack	33
6.5.1	The Backdoor Architecture	33
6.5.2	Escalation Upon Detection: Attacking the Responders	33
6.5.3	Attribution and Legal Aftermath	34
6.6	Impact Analysis	34
6.7	Mapping to the CIA Triad	34
6.8	Defensive Lessons	37
7	Defense strategies and Risk mitigation	39
7.1	Overview of Defense Strategies	39
7.2	Defense-in-Depth Model	39
7.2.1	Concept of Defense-in-Depth	39
7.2.2	Integration of the AAA Access Control Framework	40
7.3	Enhancing Access Control and User Authentication	40
7.3.1	Role of Authentication in Preventing Attacks	40
7.3.2	Weaknesses of Single-Factor Authentication (SFA) and Common At- tack Methods	40
7.3.3	Levels of Upgrading Authentication Strategy	41
7.3.4	Real-world Case Study: Security Transformation at Google	41
7.4	Patch Management Process and Risk Reduction	42
7.4.1	Concept and Importance of Patch Management	42
7.4.2	Standard Patch Management Process	42
7.4.3	Real-world Case Study: WannaCry Ransomware Disaster	42
7.5	Data Backup Strategy and the 3-2-1 Rule	43
7.5.1	Importance of Backup in Security	43
7.5.2	Gold Standard: The 3-2-1 Backup Rule	43
7.5.3	Enhanced Defense: Immutable and Air-gapped Backup	43
7.5.4	Core Benefits and Practical Application	43
7.6	Incident Response Lifecycle	44
7.6.1	Importance of Incident Response	44
7.6.2	Six Phases of the Incident Response Lifecycle	44
7.6.3	Real-world Example (Ransomware Response Scenario)	44
7.7	User Awareness and Security Recommendations	45
7.7.1	Humans: The Weakest Link	45
7.7.2	Common Risky Behaviors	45
7.7.3	Recommendations and Solutions	45
7.8	Future Trends and Conclusion	45
7.8.1	Emerging Cybersecurity Threats	45
7.8.2	Overall Conclusion	46
8	Future Trends in Malicious Software	47

8.1	AI-Powered and Autonomous Malware	47
8.2	Fileless Malware and "Living-off-the-Land" (LotL)	47
8.3	IoT Botnets and Critical Infrastructure Threats	47
8.4	Ransomware 3.0: The Triple Extortion Model	48
8.5	Supply Chain Attacks (Software Poisoning)	48
9	Conclusion	49
9.1	Final Summary of Key Lessons	49
9.2	The Reality in Vietnam	49
9.3	Final Words	49
	References	50

List of Figures

1	Attack surface progression from identity compromise to on-prem operational impact	32
2	Complete attack chain of the MGM Resorts cyberattack (September 2023) .	35
3	Day-by-day response timeline of the MGM incident (Sep 8–19, 2023)	35
4	Security reports indicate that implementing MFA can prevent more than 99% of automated account takeover attacks [1].	41

List of Tables

1	List of group members	6
2	Task distribution and completion status	6
3	Incident impact summary for the MGM Resorts cyberattack	36
4	CIA triad mapping for the MGM Resorts incident	37

Group Members

No.	Full Name	Student ID	Email
1	Đỗm Quang Minh Triết	23127131	dqmtriet23@clc.fitus.edu.vn
2	Đinh Đại Vũ	23127144	ddvu23@clc.fitus.edu.vn
3	Lê Phạm Kiều Duyên	23127184	lpkduyen23@clc.fitus.edu.vn
4	Lê Trương Bảo Ngọc	23127237	ltbngoc23@clc.fitus.edu.vn
5	Nguyễn Đăng Phôn	23127451	ndphon23@clc.fitus.edu.vn

Table 1: List of group members

Task Distribution and Completion Status

No.	Task	Responsible	Student ID	Contribution
1	Defense and Mitigation Strategies	Đỗm Quang Minh Triết	23127131	20%
2		Đinh Đại Vũ	23127144	20%
3		Lê Phạm Kiều Duyên	23127184	20%
4		Lê Trương Bảo Ngọc	23127237	20%
5		Nguyễn Đăng Phôn	23127451	20%

Table 2: Task distribution and completion status

1 Introduction and Scope of Research

Malicious software, commonly referred to as malware, represents one of the most persistent and evolving threats in the digital landscape. As defined in information security literature, malware is any program or set of instructions designed to perform unauthorized operations on a system without the user’s consent [2]. From early “sneakernet” transmissions via floppy disks to today’s advanced, multi-stage, and stealth-enabled campaigns, malware has evolved from an academic curiosity into a mature criminal and geopolitical instrument.

To evaluate this threat rigorously, malware impact should be examined through core security principles and operational risk lenses.

1.1 Alignment with the CIA Triad

To fully comprehend the danger posed by malware, its consequences must be mapped to the CIA Triad (Confidentiality, Integrity, and Availability):

- **Confidentiality:** Malware such as spyware, keyloggers, and credential-stealing trojans is engineered to covertly exfiltrate sensitive information, including login credentials, personal records, and intellectual property.
- **Integrity:** Viruses and worms can alter system files, inject malicious instructions into legitimate applications, and corrupt data flows, thereby undermining trust in information correctness and system behavior [2].
- **Availability:** Ransomware encrypts critical data while botnets launch distributed denial-of-service campaigns; both tactics degrade or completely disrupt service availability.

Using the CIA Triad as an analytical frame clarifies how malware transforms technical compromise into business, legal, and societal impact.

1.2 Scope of Research

This report treats malware as a full lifecycle problem, from origin and propagation to detection, response, and long-term resilience. The scope of research is organized into the following domains:

1. **Classification and Architecture:** analysis of internal behavior and propagation models across malware families, including viruses, worms, trojan horses, logic bombs, spyware, adware, botnets, keystroke loggers, and malicious browser extensions.
2. **Vulnerabilities and Enablers:** examination of technical and operational conditions that allow malware execution, with emphasis on active content abuse, homepage hijacking, and web server compromise patterns.
3. **Attack Vectors and Methodology:** discussion of attacker entry pathways, including social engineering, spam delivery, software vulnerability exploitation, and DoS/DDoS operations.
4. **Anatomy of an Attack:** attacker motivation models, objective categories, structured vs. unstructured attack styles, and phased execution from reconnaissance to trace-covering.

5. **Future Trends:** projection of evolving threats such as AI-assisted malware, fileless techniques, IoT botnets, triple-extortion ransomware, and software supply-chain compromise.
6. **Implications for Defense:** synthesis of lessons for layered protection, incident readiness, and cyber resilience in modern organizations.

Together, these sections provide a structured foundation for understanding malware not merely as malicious code, but as a socio-technical threat ecosystem requiring layered and continuously adaptive defense.

2 Classification and Architecture of Malicious Software

2.1 Overview

Malware (malicious software) refers to programs that run on a computer and perform actions the user does not intend. Attackers can cause harm in several ways:

- Gaining administrative control of a system to issue harmful commands.
- Establishing command-and-control (C2) channels that allow attackers to send remote commands executed by the infected system.
- Propagating through various attack vectors, including removable media (e.g., USB drives or malicious USB cables) and network-based channels such as the Internet.
- Using legitimate remote administration tools to scan for and exploit system vulnerabilities.

2.2 Classification

Most computer users refer to any malicious code as a virus; however, in reality, there are several types of viruses as well as many other forms of malicious code. Each of these has unique characteristics and architectures, and therefore requires different approaches to defend against them.

2.2.1 Viruses

Definition. A computer virus is a software program that attaches itself to or replicates by inserting its code into another executable program on a computer. Its core purpose is to trick the system into executing actions that were not intended by the original program's developer.

Characteristics.

- **Dependency:** A virus typically requires user interaction, such as executing an infected file, to activate and infect a host program.
- **Propagation Mechanism:** It spreads by attaching itself to executable files and replicating.
- **Payload Behavior:** The virus may carry a payload that is destructive, hidden, or non-malicious.
- **Stealth and Persistence:** Some viruses hide their payload or install backdoors, enabling long-term undetected access.

Propagation Mechanisms.

- **System infectors:** They target system boot functions, typically the Master Boot Record (MBR), to gain control before protective mechanisms are loaded.
- **File infectors:** Attach to executable files to replicate and spread. They primarily target Windows systems and, in some cases, may also affect mobile and IoT devices. These

viruses control program execution to replicate and may deliver a payload. Companion viruses exploit file extension priority to execute before legitimate programs.

- Data/Macro infectors: Infect document files containing macros, allowing malware to spread when files are opened or shared. They are easy to create, cross-platform, and commonly delivered via malicious email attachments or shared templates.

Other Virus Classifications. Most viruses propagate by copying exact replicas of themselves to infected files or systems, creating predictable signatures that antivirus software can detect. However, some viruses employ advanced techniques to evade detection, including:

- Polymorphic viruses
- Stealth viruses
- Slow viruses
- Retro viruses
- Cross-platform viruses
- Multipartite viruses

Examples. Examples of historically significant computer viruses include: [2]

- ILOVEYOU (2000)
- Klez (2001)
- Nimda (2001)
- Sasser (2004)
- Conficker (2008)
- Shamoon (2012 and 2016)

Detection. Virus infections may be detected through reduced system performance, abnormal disk or memory usage, frequent system crashes or errors, unexpected antivirus alerts, and unusual file or application behavior.

2.2.2 Worms

Definition. Worms are self-contained malware programs that propagate automatically from one host to another using network communication protocols, without requiring a host program or user interaction.

Characteristics.

- Do not attach to executable files.
- Operate independently as standalone programs.

- Spread rapidly across networks.
- Consist of components running on multiple systems and communicating over a network.

Propagation Mechanisms.

- Independence and autonomous operation: Worms are self-contained programs capable of self-replication and network-based propagation without attaching themselves to a host program, unlike computer viruses.
- No human interaction required: The propagation process occurs fully automatically and does not require any user action or interaction to initiate infection.
- Scanning and vulnerability exploitation: Worms actively scan network-connected systems to identify and exploit specific software or operating system vulnerabilities, such as buffer overflow flaws or remote code execution vulnerabilities.
- Email-based propagation: After compromising a host, worms may harvest email addresses from the system and automatically send copies of themselves to other targets via the Simple Mail Transfer Protocol (SMTP) or the host's email infrastructure.
- Multiple infection vectors: In addition to email, worms can spread rapidly through shared network drives, misconfigured services, or compromised websites.
- Termination conditions: Propagation continues until the worm is detected and contained by security mechanisms, or until security patches are applied to eliminate the exploited vulnerabilities.

Examples. Notable worms include:

- Morris Worm
- Conficker
- Stuxnet
- WannaCry
- Sobig.F
- Blaster
- Linux worms such as L10n, Badbunny, and Darloz

Detection. Worm infections may be detected through:

- Unexplained increases in bandwidth consumption.
- High volumes of inbound and outbound email or other network traffic during normal activity periods.
- Unexplained decreases in available disk space.
- Unusual increases in average message size or the volume of attachments.

- Unexpected Simple Mail Transfer Protocol (SMTP) or Post Office Protocol 3 (POP3) daemon responses.
- Sudden increases in user response times across the network or sudden congestion at chokepoints near server clusters.

2.2.3 Trojan Horses

Definition. Trojan horses represent one of the most prevalent and diverse categories of malware. A Trojan horse is any program that masquerades as a useful or legitimate application while hiding its malicious intent. Trojans typically encourage users to download and execute the program voluntarily.

Characteristics.

- Information theft: Trojan horses are often designed to steal sensitive information such as passwords, banking credentials, and personal data stored on the victim's system.
- Remote access: A Trojan may grant attackers remote access, allowing them to control the infected system without the user's knowledge or consent.
- Data deletion or corruption: Some Trojans delete or corrupt files, leading to data loss or system instability.

Propagation Mechanisms. Trojan horses are distributed through multiple delivery methods:

- Email attachments: Trojans are often attached to malicious or fake emails. When users download and open the attachment, the Trojan installs itself and may execute automatically on system startup or file access.
- Social engineering: Attackers trick users into installing Trojans through malicious links, pop-up advertisements, fake software updates, or deceptive banner ads.
- Infected devices: Once a device is compromised, the Trojan may spread to other systems via networks or removable media. Infected machines can be remotely controlled and used as part of a botnet.

Examples. Common types of Trojan horses include:

- Backdoor Trojan
- Exploit Trojan
- Banker Trojan
- DDoS Trojan
- Downloader Trojan

Detection. Trojan infections may be detected through:

- Unrecognized or suspicious new processes running on the system.
- Startup messages indicating unexpected software installation or registry updates.
- Applications becoming unresponsive to normal commands.
- Unusual redirection of web requests to unknown or malicious websites.
- Unexpected remote logon prompts at unusual times or unfamiliar logon interfaces.
- Sudden termination or failure of antivirus or personal firewall software.

2.2.4 Logic Bombs

Definition. A logic bomb is a program that executes a malicious function when specific conditions are met or at a predetermined time.

Characteristics.

- Malicious tasks may cause immediate damage or initiate a sequence of events that results in damage over an extended period.
- Logic bombs are often associated with insider threats, as insiders typically possess detailed knowledge of organizational systems.
- Remain dormant while waiting for specific conditions or a triggering time.

Activation Mechanism.

- Logic bombs are usually embedded and concealed within legitimate software by individuals who have authorized access to the system.

Examples.

- A common example involves a programmer embedding a logic bomb into company software that automatically deletes critical files or causes system damage if the programmer is terminated.

Detection.

- Logic bombs are difficult to detect because they are deliberately designed to remain hidden until activation.
- Designers often understand organizational security controls and place logic bombs in locations that are unlikely to attract attention.

2.2.5 Spyware

Definition. Spyware is any unsolicited background process that installs itself on a user's computer without the user's knowledge or consent. It is designed to collect information about the user's browsing habits, website activities, and potentially sensitive personal data.

Characteristics.

- Data collection: Gathers sensitive personal information such as account credentials, balances, and other private data for identity theft or fraud.
- Keystroke logging: Records all keystrokes, including passwords, emails, and chat messages.
- Activity tracking: Monitors online behavior such as visited websites, search queries, and social media activity to analyze patterns or deliver targeted advertisements.
- Screen capturing: Takes screenshots of the device screen, potentially exposing confidential information.
- Remote control: Some advanced spyware variants include remote access capabilities.

Distribution Mechanisms.

- Phishing: Spyware enters the system when users click malicious links or download infected attachments.
- Spoofing: Attackers disguise malicious emails as legitimate messages to trick users into installing spyware.
- Freeware/Shareware bundling: Spyware is bundled with free or shared software during installation.
- Misleading software: Fake optimization or utility programs secretly install spyware to steal confidential information.

Examples.

- Pegasus: A highly sophisticated and targeted spyware platform primarily used for surveillance by state-level actors.

Detection.

- Slow system performance, frequent freezing, or unexpected crashes due to excessive resource consumption.
- Unusual network activity, such as abnormally high traffic or excessive outbound connections.
- Frequent and unexpected pop-up windows or advertisements.
- Unwanted changes to browser settings, including homepage, search engine, or bookmarks.
- Appearance of unfamiliar or suspicious programs or running processes.

Spyware detection typically relies on endpoint protection platforms, behavioral analysis, network traffic monitoring, and specialized anti-spyware tools.

2.2.6 Adware

Definition. Adware is a type of software designed to automatically display or download advertising material, such as pop-up windows and banner advertisements, often without the user's consent.

Characteristics.

- Disruption: Adware triggers intrusive behaviors such as pop-up windows and banner advertisements when users visit certain websites.
- Productivity impact: Adware negatively affects user productivity and overall system performance.
- Privacy risk: Adware may track user behavior to deliver targeted advertisements, potentially violating user privacy.

Propagation Mechanisms.

- Adware is commonly bundled with freeware or shareware and is unknowingly installed by users during software installation.
- It may also be distributed through deceptive pop-up windows or misleading download prompts.

Examples.

- Web banners
- Pop-up advertisements
- Browser toolbars
- In-text advertisements injected into webpages

Prevention.

- Download software only from official websites or reputable sources.
- Read license agreements carefully and use custom installation options to decline bundled programs.
- Regularly update the operating system and applications to patch security vulnerabilities.
- Use reliable security software for additional protection.
- Avoid clicking suspicious links or downloading attachments from unknown sources.
- Be cautious of websites that trigger unexpected downloads.
- Stay informed about emerging adware threats and share knowledge to promote safer online practices.

2.2.7 Botnets

Definition. Botnets (short for robotically controlled networks) are networks of compromised computers that are remotely controlled by an attacker. The individual who manages and issues commands to the botnet is commonly referred to as a bot-herder or controller. In simple terms, a botnet is a collection of Internet-connected devices coordinated to perform malicious activities.

Characteristics.

- Remote control: Early botnets primarily used Internet Relay Chat (IRC) channels for communication, whereas modern botnets increasingly rely on HTTP/HTTPS, peer-to-peer architectures, or cloud-based services to evade detection.
- Use of agents: Attackers install software agents on compromised systems to execute commands and perform malicious tasks.
- High computational power: Botnets can generate enormous computing power; in some cases, their combined performance has rivaled that of the world's most powerful super-computers.
- Resilience: Botnets are difficult to dismantle because they are distributed across a large number of geographically dispersed systems.

Propagation Mechanisms.

- Exploiting vulnerabilities: Attackers scan for systems with security vulnerabilities and install botnet control agents upon successful compromise.
- Self-replication via malware: Many modern viruses and worms contain components that convert infected machines into botnet nodes.
- Spam distribution: Infected machines (often called zombies) are used to send spam emails containing malware to propagate the botnet further.

Examples.

- Storm botnet: In 2007, it was recorded as one of the most powerful computer networks in the world at that time.
- Attacks on U.S. banks (2012–2013): Botnets were used to carry out large-scale attacks against major U.S. financial institutions and infrastructure.

Detection.

- Detecting botnets is challenging because they are distributed across numerous personal computers, servers, and devices.
- Tracing and identifying the bot-herder is difficult, as control may be exercised from locations far removed from the infected systems.
- Securing all computing devices, including Internet of Things (IoT) devices, is essential to prevent their exploitation as botnet participants.

2.2.8 Keystroke Loggers

Definition. A keystroke logger is a type of software or hardware monitoring tool capable of recording every keystroke a user makes on a keyboard into a log file. The recorded data may be stored locally for later retrieval or transmitted over a network to a designated recipient.

Characteristics.

- Monitoring tool: Keystroke loggers function as tracking tools and may be embedded within spyware to steal passwords and personal information.
- Dual-use nature: Keystroke loggers can be used legitimately by organizations to monitor employee productivity, but are frequently abused by cybercriminals for malicious purposes.
- Stealthy operation: Hardware-based keystroke loggers are typically small and designed to be hidden in inconspicuous locations, such as behind a computer or within cable connections.

Propagation Mechanisms.

- Physical form: Hardware keystroke loggers require the attacker to physically connect an intermediary device between the keyboard and the computer's input port.
- Software form: Software-based keystroke loggers are commonly distributed as Trojan malware via malicious URLs, email attachments (e.g., PDF or ZIP files), or stealthily installed as part of a rootkit after system compromise.

Examples.

- Hardware: Plug-in devices approximately the size of a battery that attach to USB or legacy keyboard ports and store keystroke data internally.
- Software: Malicious programs that record keystrokes and periodically transmit the collected data to attackers over the Internet without the user's knowledge.

Detection.

- Physical inspection: Manually inspect keyboard and computer ports for unfamiliar or unauthorized devices.
- Security software: Use antivirus and anti-malware tools to scan for suspicious processes or keystroke-recording software.
- System monitoring: Monitor system behavior, review activity logs, and identify unknown or suspicious network connections.

2.2.9 Malicious Add-Ons (Browser Extensions)

Definition. Browser add-ons (also known as extensions) are companion programs that operate alongside a web browser to extend its functionality, such as integrating news feeds

or weather alerts. Malicious add-ons are browser extensions that contain embedded malware.

Characteristics.

- Reduced security: Malicious add-ons lower the overall security level of the web browser and the underlying computer system.
- Unauthorized actions: Once installed, these extensions can perform various malicious activities using the browser's privileges.
- Disguised nature: They often appear to be legitimate or useful tools while secretly carrying out harmful actions.

Propagation Mechanisms.

- Voluntary but uncontrolled installation: Users may install malicious add-ons unknowingly, believing them to be legitimate extensions.
- Untrusted sources: These add-ons are commonly distributed through unreliable websites or unknown extension providers.

Examples.

- Malicious browser toolbars designed to track user activity or display unauthorized advertisements.
- Deceptive extensions that claim to offer features such as news updates, weather information, or system optimization but instead install malware.

Detection.

- Exercise caution when installing browser extensions and use only trusted sources.
- Regularly review installed add-ons to ensure all extensions are recognized and necessary.

3 Vulnerabilities and Malware Enablers

To better understand how malware operates, it is crucial to examine the methods and techniques used by attackers. These techniques exploit system vulnerabilities, allowing malicious code to infiltrate systems and cause harm. In this section, we explore common attack methods and analyze how malware targets computer systems and networks.

3.1 Active Content Vulnerabilities

Definition. Active content refers to components, primarily on web pages, that provide functionality for interacting with users. This includes any dynamic object that performs an action when a user opens a web page. Common technologies used to implement active content include ActiveX, Java, JavaScript, VBScript, scripts, browser plug-ins, and PDF files.

How It Works. Active content is considered a form of mobile code because it can execute across different computing platforms. When a user visits a website, the web browser downloads this code and executes it within the browser's context, using the user's credentials and privileges. Once downloaded, the mobile code may gain access to local system resources, including the computer's hard drive.

Attack Techniques. Attackers exploit weaknesses in active content mechanisms to execute malicious code. A common attack technique is Cross-Site Scripting (XSS), which allows attackers to inject client-side scripts into web pages viewed by users. When a user accesses such a page, the browser automatically executes the malicious script, often bypassing access control mechanisms.

Impact. Malicious active content can cause severe consequences, such as flooding the desktop with icons representing malware-infected files. These files may continue to replicate and generate additional copies of the malicious code. The overall impact depends on the sensitivity of the compromised system and the data it contains.

Prevention.

- Browser configuration: Configure browser security settings to block or warn users before executing scripts or dynamic content.
- Content filtering: Implement network-level filtering to analyze traffic, identify dynamic code components (e.g., Java or ActiveX), and disable script processing within web browsers.
- Pop-up blocking: Require users to enable pop-up blockers to prevent automatic pop-up windows and reduce the risk of unintentional malware execution.

3.2 Homepage Hijacking

Definition. Homepage hijacking is a type of attack that alters a web browser's homepage configuration so that it redirects users to a website chosen by the attacker.

How It Works. This attack resets the browser's homepage settings, typically without the user's permission. Attackers may install hidden programs that preserve the malicious configuration even when the user attempts to restore the original homepage.

Attack Techniques. Attackers commonly use the following methods to perform homepage hijacking:

- Exploiting browser vulnerabilities: Taking advantage of security flaws in web browsers or active content components to modify homepage settings.
- Social engineering: Tricking users into performing actions that appear beneficial but actually initiate malware execution (e.g., fake buttons claiming to remove infections).
- Browser Helper Objects (BHOs): Installing Trojan programs in the form of BHOs that register themselves in the system startup process and execute automatically each time the system boots.

Impact.

- The browser repeatedly opens the attacker's website instead of the user's preferred homepage.
- Persistent annoyance and loss of control, as hijacking programs continuously reset the homepage until the malware is fully removed.

Prevention.

- Exercise caution when interacting with websites, especially when clicking buttons or links from unknown or untrusted sources.
- Review system startup processes and remove suspicious or unauthorized entries.
- Fully identify and eliminate malicious programs or Browser Helper Objects to prevent repeated homepage changes.

3.3 Webpage Defacements

Definition. Webpage defacement (also known as web graffiti) is the act of gaining unauthorized access to a web server and altering the content of the index page or other web pages hosted on that server.

How It Works. Attackers typically target publicly accessible web servers on the Internet. The attack process involves identifying and exploiting known security vulnerabilities to gain administrative or elevated access. Once control is obtained, the attackers replace legitimate web pages with modified or malicious versions.

Attack Techniques.

- Exploiting software vulnerabilities: Attackers exploit security flaws in the server's operating system or service applications (e.g., vulnerabilities in web servers) to gain unauthorized access.

- Installing backdoors: Some malware installs Trojan backdoors after infection, enabling attackers to remotely access the server and alter website content at any time.
- Using automated tools: Script kiddies and organized hacker groups often use automated vulnerability-scanning tools to identify poorly secured websites before launching attacks.

Impact.

- Defacement and nuisance: Webpage defacement is often considered a form of digital graffiti that disrupts normal website operations.
- Reputational damage: Defaced websites may display offensive messages or inappropriate content, damaging organizational credibility and user trust.
- Serious security risks: Attackers may embed malicious active content, such as viruses or Trojan programs, exposing visitors to further compromise.

Prevention.

- Software updates: Keep web server operating systems and applications up to date with the latest security patches.
- Disabling unnecessary services: Turn off unused services and close unneeded network ports to reduce attack surfaces.
- Network defense layers: Use proxy servers or bastion hosts to protect critical services and filter malicious traffic.
- Monitoring and testing: Conduct regular vulnerability assessments and penetration testing to identify and remediate weaknesses proactively.

4 Attack Vectors

Attack vectors refer to the methods or pathways used by attackers to gain unauthorised access to systems, networks, or data. Understanding attack vectors is critical for analysing how attacks are initiated and for designing effective defensive strategies. Common attack vectors exploit human behaviour, technical vulnerabilities, or weaknesses in system availability.

4.1 Social Engineering and Phishing

Social engineering attacks exploit human psychology rather than technical vulnerabilities to gain access to sensitive information or systems. Attackers manipulate victims into revealing credentials, downloading malicious files, or performing actions that compromise security. Phishing is one of the most prevalent forms of social engineering and typically involves deceptive emails, messages, or websites that impersonate legitimate entities. These attacks often create a sense of urgency or authority to pressure victims into compliance. Due to their reliance on human error, social engineering and phishing attacks remain highly effective despite advancements in technical security controls.

Real-world example: The Twilio Breach (2022). Attackers sent SMS messages to Twilio employees pretending to be the IT department, urging them to update their passwords or review new schedules. The texts contained the employee’s actual names and legit-looking URLs leading to a fake Twilio sign-in page. Some workers tried to log in, revealing their user credentials [3].

4.2 Spam-Based Attacks

Spam-based attacks involve the mass distribution of unsolicited messages containing malicious links, attachments, or payloads. Unlike targeted phishing campaigns, spam-based attacks are typically indiscriminate and aim to infect a large number of systems with minimal effort. These attacks are commonly used to spread malware, ransomware, or trojans and often rely on at least some recipients interacting with the malicious content. Spam-based attacks are frequently used as an initial delivery mechanism in larger attack campaigns.

Real-world example: The Emotet Botnet. Before its disruption, Emotet was the world’s most dangerous malware distributor, largely spreading via massive spam campaigns containing malicious Word documents (fake invoices or shipping receipts). It served as the primary delivery mechanism for other ransomware like Ryuk [4].

4.3 Software Vulnerability Exploitation

Software vulnerability exploitation occurs when attackers take advantage of flaws in operating systems, applications, or network services. These vulnerabilities may arise from coding errors, misconfigurations, or outdated software lacking security patches. Attackers often use automated tools or exploit frameworks to identify and exploit known vulnerabilities, although advanced attackers may leverage zero-day vulnerabilities that have not yet been publicly disclosed. Successful exploitation can lead to unauthorized access, privilege escalation, or remote code execution.

Real-world example: Log4Shell (CVE-2021-44228). Discovered in late 2021, this critical vulnerability affected Apache Log4j, a widely used logging library in Java applications. At

the peak of Log4Shell activity, Check Point observed more than 100 attacks every minute, affecting more than 40% of all business networks globally [5] [6].

4.4 Denial of Service (DoS/DDoS)

Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks aim to disrupt the availability of systems or services by overwhelming them with excessive traffic or resource requests. In a DDoS attack, multiple compromised systems, often part of a botnet, are used to amplify the attack's impact. These attacks do not necessarily involve data theft but can cause significant operational and financial damage by rendering services inaccessible to legitimate users.

Real-world example: The Dyn Cyberattack (2016). The Mirai Botnet, composed of insecure IoT devices (cameras, routers), launched a massive DDoS attack against Dyn (a DNS provider). This attack successfully took down major platforms like Twitter, Netflix, and Reddit for hours, highlighting the power of volumetric attacks [7].

[8]

5 Anatomy of an Attack

In order to develop practical and efficacious countermeasures, it is essential that the objectives, the key targets, and the characteristics of an attack must be known.

5.1 What Motivates Attackers?

Contrary to popular belief, today's attackers are not merely socially marginalised individuals driven by thrill-seeking impulses or amateur experimentation. There is much more complexity to the reasons behind attacks, namely:

- Monetary gain:
 - Objective: To generate illicit profit through theft or extortion.
 - A real-life example: Hieu Ngo Minh, also known as Hieu PC, a Vietnamese hacker who was formerly involved in identity-theft operations, stole and sold large volumes of personally identifiable information, including millions of U.S. Social Security numbers. His activities generated substantial illegal profits and caused significant financial damage. In his 20s, he made roughly \$100,000 just by hacking and selling [9]. He later admitted that he was motivated by financial pressure and his own greed.

[10]

- Attention-seeking behaviours or notoriety gain:
 - Objective: Mainly to achieve fame and recognition in cyberspace.
 - A real-life example: The hacker group LulzSec carried out a series of high-profile cyberattacks in 2011 targeting organisations such as Sony, PBS, and Fox. Rather than focusing on financial profit, the group aimed to embarrass companies and demonstrate security flaws to gain notoriety. Their attacks exposed millions of users' data and generated widespread media coverage.

[11]

- The imposition of beliefs or systems on others:
 - Objective: To promote political, social, or ideological agendas by influencing public opinion.
 - A real-life example: Anonymous is an international collective, a group of hacktivists that distorts the line between activism and cybercrime. Over the years, Anonymous has executed campaigns targeting a variety of organisations such as PayPal and Sony, in response to perceived injustices or threats to free speech. Significant campaigns include Project Chanology, Operation Payback, and more recent actions in support of the Black Lives Matter movement following George Floyd's death.

[12] [13]

- Personal anger:
 - Objective: To exact revenge due to personal conflicts.

- A real-life example: In 2000, the Maroochy Water Services attack in Australia involved a former employee, Vitek Boden, who used his insider knowledge of SCADA systems to manipulate sewage infrastructure. He left his job after a rocky relationship with his employer and was denied a job position after applying for the Maroochy Shire Council. His actions released hundreds of thousands of litres of sewage into local waterways and thus causing pollution.

[14]

- Nation-state cyberwarfare:
 - Objective: To achieve strategic geopolitical or military advantages by disrupting critical infrastructure or intelligence capabilities.
 - A real-life example: Stuxnet (2010) is widely considered the first digital weapon used for cyberwarfare. It was a sophisticated computer worm, allegedly developed by the United States and Israel, designed specifically to target Iran’s nuclear program. It specifically infected computers controlling the centrifuges at the Natanz nuclear facility, causing them to operate irregularly and degrade faster than normal, thus hindering uranium enrichment efforts.

[15] [16]

- Economic espionage:
 - Objective: To obtain intellectual property, trade secrets, or sensitive business information for economic or technological advantage.
 - A real-life example: In 2026, a former Google engineer, Linwei Ding, was convicted of economic espionage after stealing more than 2,000 confidential AI-related documents while employed at the company. Prosecutors stated that the stolen information contained sensitive trade secrets that could benefit two Chinese companies he was secretly working for.

[17] [18]

5.2 The Purpose of an Attack

There are four primary purposes of an attack:

- Denial of availability: To prevent legitimate users from accessing a system or data.
- Data modification: To modify, delete, or overwrite files on a local or network drive. Alternatively, the goals might be the modification of system settings or browser security settings.
- Data export (exfiltration): To steal information and transfer it to external destination.
- Launch point: To target a device as a launch point to infect and target other devices as part of a greater attack plan.

5.3 Types of Attacks

5.3.1 Unstructured Attacks

- Characteristics:
 - Frequently executed by moderately skilled attackers targeting network resources.
 - Limited planning.
 - Utilising existing scripts, toolkits, or automated exploits available on the Internet to scan for known vulnerabilities.
- Motivation: To achieve personal gratification, such as the thrill of overcoming security measures, gaining illegal access, or earning recognition within hacker communities.
- Target: Publicly accessible network resources, vulnerable websites, or systems discovered through automated scanning for known weaknesses.
- Impact: Unstructured attacks may lead to website defacement, accidental system crashes, data exposure, or the discovery of unintended vulnerabilities that can later be exploited through more organised attacks.
- A case in point: The "Mafiaboy" DDoS Attacks (2000), Michael Calce, a 15-year-old Canadian high school student known as "Mafiaboy," launched a series of massive Denial-of-Service attacks against major industry giants, including Yahoo!, CNN, eBay, and Amazon.

[19]

5.3.2 Structured attacks

- Characteristics:
 - Carefully planned and methodical in nature.
 - Typically carried out by highly skilled attackers or organised groups.
 - Involve sophisticated hacking techniques to identify, probe, penetrate, and carry out malicious activities.
- Motivation: Financial gain, political or ideological objectives, retaliation, or strategic advantage.
- Target: Specific and high-value targets, such as government agencies, large enterprises, critical infrastructure, or individuals with privileged access.
- Impact: Can lead to severe and long-term consequences, including large-scale data breaches, service disruption, financial losses, and compromise of critical systems.
- A case in point: Carried out by a highly sophisticated sponsored group (identified as Nobelium/APT29), the attackers compromised the build system of the SolarWinds Orion platform. By injecting the "Sunburst" backdoor into legitimate software updates, they successfully infiltrated over 18,000 organisations, including high-value targets such

as government departments, namely Homeland Security, State, Commerce and Treasury were affected. The attack remained undetected for months, which is the manifestation of the extreme planning and patience characteristic of a typical structured threat.

[20] [21]

5.3.3 Direct Attacks

- Characteristics:
 - Executed in real time, where attackers interact directly with the target system.
 - Might involve remote logon attempts, password guessing, session hijacking, or exploitation of known software vulnerabilities.
 - Can be either unstructured or structured, depending on the attacker's skill level and planning.
- Motivation: Varies from personal gratification and experimentation to financial gain, disruption, or preparation for larger coordinated attacks.
- Target: Specific organisations, individual systems, or classes of targets such as networks running particular hardware, operating systems, or vulnerable services.
- Impact: Direct attacks may result in website defacement, unauthorised access, malware implantation, or the compromise of internal network resources, potentially enabling further attacks.
- A case in point: The MOVEit Transfer exploit (2023), where attackers (CL0P) exploited a vulnerability in file-transfer software to directly access sensitive data from organisations worldwide. This zero-day vulnerability enabled attackers to exploit public-facing servers via SQL injection, facilitating unauthorised file theft.

[22]

5.3.4 Indirect Attacks

- Characteristics:
 - Executed by preprogrammed malicious code such as worms or viruses.
 - Propagate automatically and indiscriminately without direct interaction from the attacker.
 - Often exploit specific software vulnerabilities, but spread widely across networks and systems.
- Motivation: To achieve large-scale disruption, widespread infection, or to amplify the impact of an attack with minimal ongoing attacker involvement.
- Target: Broad and non-specific targets, including any vulnerable systems or networks.
- Impact: Can lead to rapid and widespread system compromise, network congestion, denial of service, data loss, and increased recovery costs for affected organisations.

- A case in point: The WannaCry ransomware worm (2017), which exploited the Eternal-Blue vulnerability in Microsoft Windows systems. Once released, the malware propagated automatically across networks without requiring continuous attacker interaction, encrypting victims' files and demanding ransom payments in cryptocurrency. The attack rapidly spread across more than 150 countries, disrupting hospitals, transportation services, and businesses worldwide.

[23] [24]

5.4 Phases of an Attack

5.4.1 Reconnaissance and Probing

- Characteristics:
 - The most important phase.
 - The initial information-gathering phase where attackers identify potential entry points and vulnerabilities.
 - Involves techniques such as DNS lookups, ICMP probing, SNMP queries, port scanning, and vulnerability assessment tools.
 - May also include collecting publicly available information about organisations, infrastructure, and personnel.
- Objective: To build a detailed profile of the target environment, including operating systems, open ports, network topology, and exposed services.
- Impact: Even without direct intrusion, reconnaissance activities can expose sensitive operational details and increase the likelihood of a successful attack.

5.4.2 Access and Privilege Escalation

- Characteristics:
 - Attackers attempt to gain unauthorised entry through exploits, stolen credentials, rogue wireless access points, or legacy remote-access services.
 - Techniques include password capturing, cracking, and deploying Remote Access Trojans (RATs) to maintain persistence.
 - Privilege escalation is often performed to obtain administrative-level control.
- Objective: To establish a stable foothold within the target system and expand control across the network.
- Impact: Successful access may lead to malware installation, lateral movement, data theft, or long-term system compromise.

5.4.3 Covering Traces of the Attack

- Characteristics:

- Attackers attempt to erase or modify logs, remove malicious files, and restore systems to a preattack state to avoid detection.
 - May involve disabling monitoring tools or bypassing auditing mechanisms.
- Objective: To conceal attacker activity and prolong unauthorised access.
- Impact: Makes incident response and forensic investigation significantly more difficult, increasing organisational risk.

[8]

6 Case Study: The MGM Resorts Cyberattack (September 2023)

6.1 Background and Context

Threat Actors: Scattered Spider (UNC3944) in coordination with ALPHV/BlackCat ransomware group

Attack Type: Structured, Direct — Social Engineering combined with Ransomware-as-a-Service (RaaS)

Primary Motivation: Financial extortion; later escalated due to what the attackers described as retaliation for failed negotiations

Duration: September 8–19, 2023 — ten days of active disruption

Scale: 29 hotel and resort properties affected worldwide, including Bellagio, MGM Grand, Mandalay Bay, and Cosmopolitan in Las Vegas. Estimated \$100 million loss in third-quarter 2023 revenue. A \$45 million class-action settlement was reached in January 2025.

The MGM Resorts attack is one of the most instructive case studies in modern cybersecurity precisely because of what it did *not* use. There was no zero-day vulnerability, no nation-state malware toolkit, no brute-force password cracking. All the attackers did to compromise a company valued at \$33.9 billion was search LinkedIn, find an employee, and call the help desk. Cyber Security Hub The entire entry into one of the world’s largest hospitality companies cost the attackers approximately ten minutes of conversation.

This case is also notable for its two-actor architecture. Scattered Spider and ALPHV/BlackCat are distinct organizations with complementary capabilities — one specializes in social engineering to obtain access, the other provides professional-grade ransomware infrastructure. Their collaboration represents what the cybersecurity industry now calls a “criminal supply chain,” a division of labor that allows non-technical attackers to cause deeply technical damage.

6.2 The Two Threat Actors

Understanding who executed this attack is essential to understanding how it worked.

Scattered Spider (UNC3944) is a loosely organized group, mostly made up of teenagers and young adults believed to live in the United States and the United Kingdom, believed to be affiliated with the cybercriminal network known as “The Com.” Wikipedia Their defining capability is fluency in English and expertise in social engineering — specifically, the ability to convincingly impersonate employees over the phone to manipulate IT help desk staff. They are not primarily technical hackers; they are manipulators who exploit organizational trust structures.

ALPHV/BlackCat is a professional ransomware-as-a-service operation. BlackCat/ALPHV is a RaaS operation — just as commercial businesses rely on SaaS applications to do their work, criminal gangs rely on RaaS. BlackCat provides the professional services that Scattered Spider lacks. CyberArk The relationship between the two groups follows a division of labor: Scattered Spider gains the access, ALPHV supplies the ransomware and handles extortion operations.

6.3 Phase 1 — Reconnaissance and Probing

6.3.1 The Intelligence Gathering

The reconnaissance phase of the MGM attack required no special tools, no network scanning, and no malware. It required only a LinkedIn account and the knowledge of what to look for.

Scattered Spider used LinkedIn to identify a current MGM Resorts employee, assumed their identity, and called the MGM IT help desk requesting assistance logging into their account. SpecopsSoft From LinkedIn, the attacker gathered the employee’s full name, job title, department, and likely their organizational reporting structure — all publicly available information that any recruiter or sales professional would access routinely. This is what security researchers call Open Source Intelligence (OSINT): the systematic exploitation of publicly available information to build an attack profile.

The target was selected deliberately. Scattered Spider did not pick a random employee — they identified someone whose role and credentials would grant useful access once impersonated. This represents a key insight about modern reconnaissance: the most dangerous intelligence gathering today does not happen on the dark web or through network intrusion. It happens on professional networking platforms that organizations actively encourage employees to use.

6.3.2 Why This Phase Is the Most Critical

Section 5.4.1 of this report identifies reconnaissance as “the most important phase” because everything that follows depends on its quality. The MGM attack demonstrates this in an extreme form. The entire technical complexity of the subsequent attack — the Okta takeover, the Azure Active Directory compromise, the deployment of ransomware across hundreds of servers — was made possible by ten minutes of social engineering built on a LinkedIn search.

The phone call lasted ten minutes, and the attackers were able to gain administrator privileges to MGM’s Okta and Azure tenant environments. University of Hawai’i–West O’ahu No malware was involved in Phase 1. No network was probed. The reconnaissance was entirely human-focused, and its product was the single most valuable thing an attacker can obtain: legitimate administrative credentials willingly handed over by the target organization itself.

6.4 Access and Privilege Escalation

6.4.1 The Entry Point: Okta

Okta is an Identity and Access Management (IAM) platform. Organizations use it as a centralized gateway that controls authentication for all their applications and services — email, cloud infrastructure, internal tools, and more. Gaining administrator access to an organization’s Okta environment is functionally equivalent to obtaining a master key to every door in a building.

This breach provided access to the Okta platform, a crucial access management system. The attackers then capitalized on weak multi-factor authentication to escalate privileges and

gain control of the Azure Active Directory domain controller. Brown & Brown The Azure Active Directory domain controller is the core identity authority for Microsoft-based cloud environments. Controlling it means controlling the ability to create, modify, and impersonate any user account in the organization.

ALPHV publicly confirmed that the affiliate group had achieved persistence in the network and had gained super administrator privileges. Morphisec With super administrator access to both the identity management layer (Okta) and the cloud directory (Azure AD), the attackers had effectively inherited the digital keys to MGM’s entire infrastructure.

6.4.2 Lateral Movement: From Cloud to Physical Operations

What makes this attack particularly instructive is how cloud-based access translated into physical-world disruption. The IdP solution granted highly privileged access to Azure, which ultimately allowed the cloud-originated attack into MGM’s brick-and-mortar operations. CyberArk The identity platform that governed digital logins was configured in a way that allowed the attackers to pivot from the cloud environment into MGM’s on-premises virtualization infrastructure.

The specific mechanism involved credential synchronization between on-premise Active Directory and the cloud. Because MGM synchronized credentials between these environments, gaining control of the cloud identity layer gave Scattered Spider a pathway into the VMware ESXi hypervisor infrastructure — the virtual machine hosts that ran the servers powering MGM’s hotel operations, gaming systems, and booking platforms.

The attack surface progression can be visualized as an identity compromise that propagated through cloud control into on-premises operations:

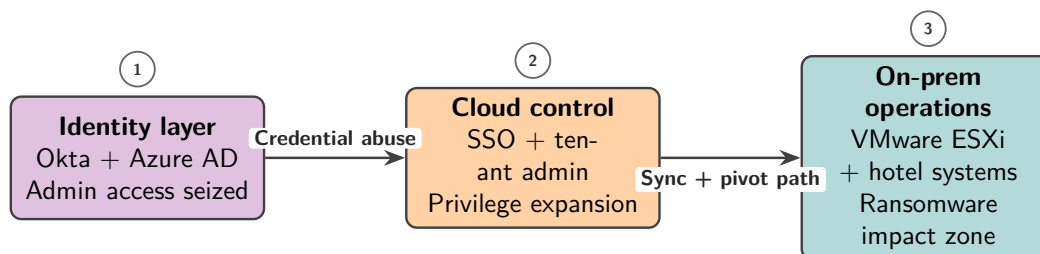


Figure 1: Attack surface progression from identity compromise to on-prem operational impact

6.4.3 Data Exfiltration: The Double-Extortion Setup

Before deploying any ransomware, the attackers ensured they had a second lever of pressure. ALPHV claims to have exfiltrated 6 TB of customer information during this time, upon which they initiated negotiations with MGM to prevent the public release of the stolen data. ALPHV also threatened to disclose the exfiltrated information if an agreement could not be reached. Netwrix

This sequencing is deliberate and important. Data theft before encryption means that even if the victim restores all systems from backup — eliminating the encryption leverage entirely — the attacker retains the ability to cause reputational and regulatory damage through data

publication. This dual-pressure structure is what the industry now calls “double extortion,” and it directly undermines the traditional defense of maintaining strong backups.

6.4.4 The Ransomware Deployment

At this stage, ALPHV/BlackCat took operational control. Using the BlackCat/ALPHV RaaS service, Scattered Spider encrypted several hundred ESXi servers, which hosted thousands of virtual machines supporting hundreds of systems widely used in the hospitality industry. This caused cascading chaos. As the ESXi hosts became encrypted one after another, the applications running on them crashed. CyberArk

The operational consequences were immediate and visible to the public. The effects of the cyberattack on MGM Resorts were immediately apparent: gambling operations were disrupted as slot machines went offline, hotel guests found their digital room keys had stopped working, online reservation and booking systems were shut down, and the MGM mobile app became completely inaccessible. Netwrix Staff reverted to pen and paper to manage guest queues. The attack had successfully converted a digital breach into a physical operational crisis.

6.5 Phase 3 — Covering Traces of the Attack

6.5.1 The Backdoor Architecture

The most forensically significant aspect of Phase 3 is that it began before MGM detected anything. The ransomware was deployed after MGM locked out the network, which means that the attackers had gained significant visibility of the network and had implanted backdoors across the network before the main attack was triggered. Morphisec

This is a critical point that separates sophisticated attackers from unsophisticated ones. By planting backdoors before becoming visible, the attackers ensured that MGM’s detection and response would not equal eviction. Even if MGM successfully expelled the attackers from their primary access route, the pre-planted backdoors would provide re-entry paths. This is the attack equivalent of having multiple escape routes prepared before a heist begins.

6.5.2 Escalation Upon Detection: Attacking the Responders

MGM’s incident response team identified the intrusion the day after initial access was gained — September 9 — when they detected unusual activity and traffic on the company’s systems. Their response was to terminate the Okta Sync servers, which was the most direct way to cut off the attacker’s credential-harvesting operations. This response was tactically correct but strategically insufficient.

ALPHV admitted to sniffing passwords on their Okta servers after the initial access. MGM hastily deactivated their Okta Sync servers and essential infrastructure components to prevent an escalation of the attack, causing the interruption of reservation systems, digital room keys, slot machines, and more. University of Hawai’i–West O’ahu The shutting down of Okta was itself what caused the guest-facing outages — meaning MGM’s defensive action created the public disruption, not the ransomware directly.

In a statement, BlackCat noted that MGM Resorts had not responded through the provided communication channel, indicating a reluctance to negotiate. The hackers highlighted that

MGM’s only response to the breach had been to disconnect each and every one of their Okta Sync servers after discovering the intrusion. Avertium The attackers, still possessing access through their pre-planted backdoors, then deployed the ransomware as an escalation — consistent with their own statement that the ransomware component was partly driven by retaliation for what they perceived as bad-faith negotiation.

6.5.3 Attribution and Legal Aftermath

Despite the attackers’ technical evasion during the operation, the group’s English-speaking, socially-visible profile made eventual attribution feasible. In July 2024, the West Midlands Police with the help of the FBI arrested a 17-year-old juvenile in connection with the MGM cyberattacks. In November 2024, 19-year-old Remington Ogletree was arrested on charges related to his alleged involvement with the group. Wikipedia

The arrests underscore a pattern: sophisticated operational security at the technical level does not compensate for poor personal operational security. Members of Scattered Spider communicated openly on Telegram channels and were identifiable through social media activity, which ultimately provided law enforcement with the leads needed to locate them despite the digital obfuscation during the attack itself.

Here is the complete attack chain from reconnaissance through ransomware deployment:

6.6 Impact Analysis

The operational consequences of the attack were severe and immediate across every dimension of MGM’s business.

Financial losses totaled approximately \$100 million in third-quarter 2023 results, with MGM reporting daily revenue losses of roughly \$8.4 million during the ten-day outage. The company additionally committed \$40 million in new cybersecurity investments following the incident, and agreed to a \$45 million class-action settlement in January 2025 covering affected customers from both the 2019 and 2023 breaches.

Operational disruption was total and publicly visible in a way that most cyberattacks are not. Slot machines displayed error messages. Digital room keys failed. Guests could not check in online, make card payments, or access their MGM loyalty accounts. Staff processed hotel transactions by hand. Airport lounges and concierge services lost access to reservation systems. For a hospitality company whose entire value proposition is seamless guest experience, this was the maximum possible reputational damage.

Regulatory and legal consequences extended beyond the settlement. MGM and Caesars Entertainment — which suffered a parallel attack by Scattered Spider the same week and paid a \$15 million ransom — were both required to file mandatory disclosures to the Securities and Exchange Commission under new cybersecurity incident rules. Moody’s Corporation noted the attack may negatively affect MGM’s credit rating due to the company’s heavy operational reliance on technology systems.

6.7 Mapping to the CIA Triad

This attack methodically violated all three pillars of the CIA Triad introduced in Chapter 1 of this report.

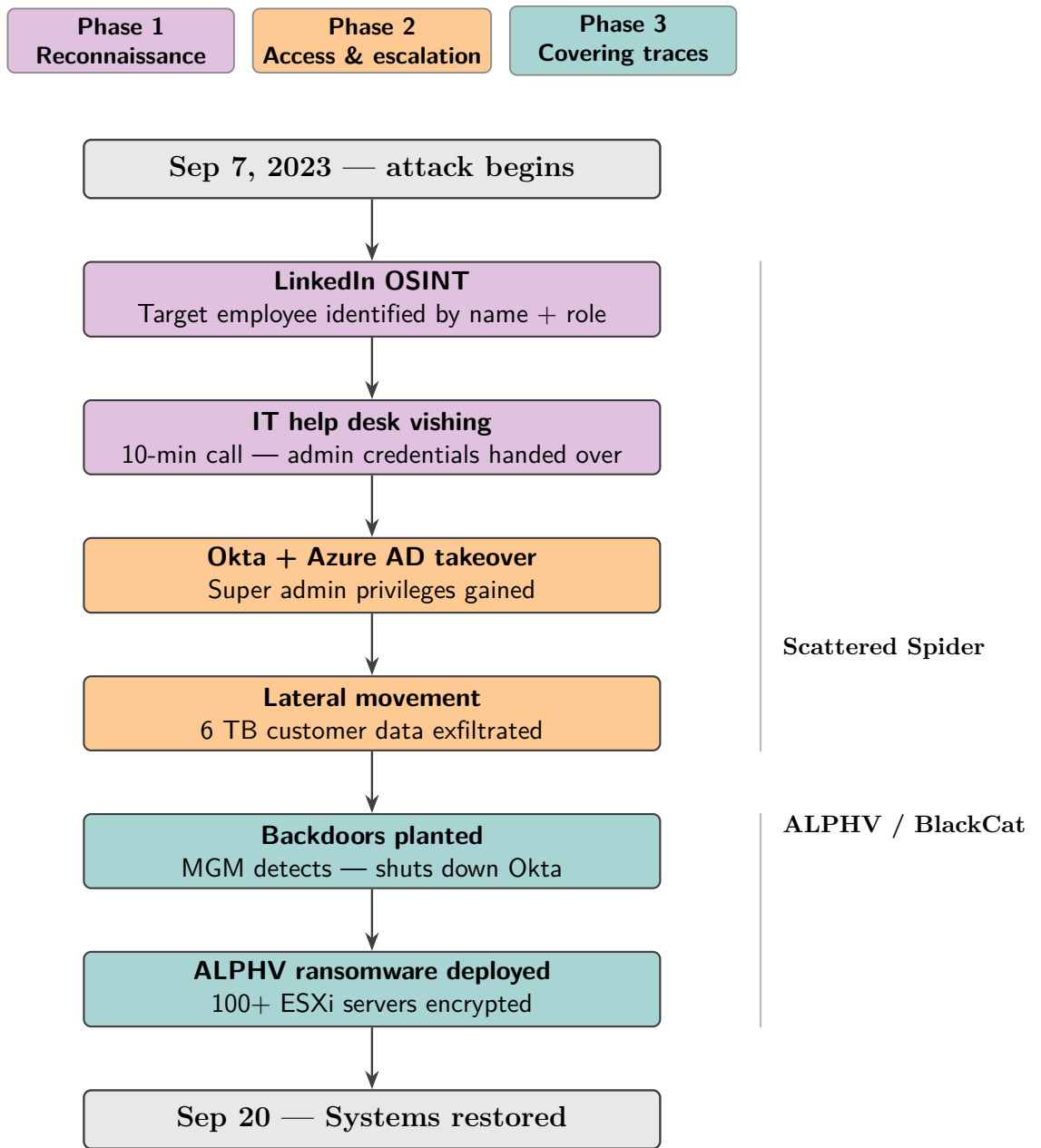


Figure 2: Complete attack chain of the MGM Resorts cyberattack (September 2023)

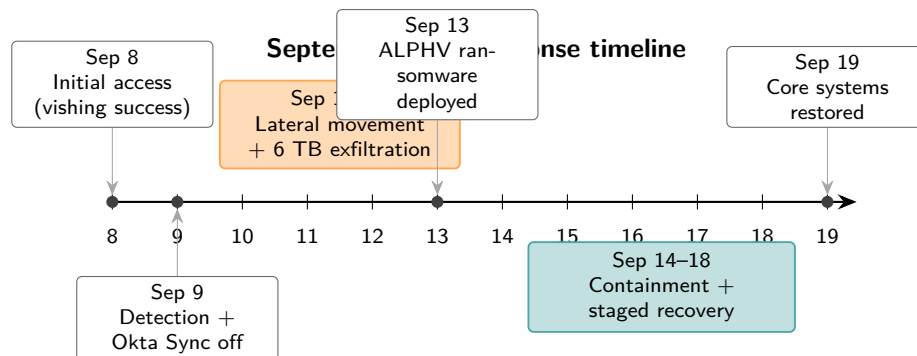


Figure 3: Day-by-day response timeline of the MGM incident (Sep 8–19, 2023)

Impact area	Evidence	Estimated loss	Duration
Financial impact	Q3 2023 revenue reduction and post-incident security spending commitments	\$100M reported outage impact; \$40M additional cybersecurity investment; \$45M class-action settlement	Approx. 10 days of active disruption; legal costs extending into 2025
Operational impact	Slot machines, room keys, booking systems, MGM app, and guest workflows disrupted; staff shifted to manual processing	Daily loss estimated at \$8.4M during outage window	Service degradation across Sep 8–19
Data exposure	Attackers claimed exfiltration of 6 TB of customer data and used leak threats in extortion	No final public total; significant legal and reputational liability exposure	Data theft occurred before encryption phase
Regulatory / legal	SEC incident disclosure obligations and class-action litigation outcomes	\$45M settlement (announced Jan 2025)	Post-incident consequences extending beyond restoration

Table 3: Incident impact summary for the MGM Resorts cyberattack

Confidentiality was breached through the exfiltration of 6 TB of customer data, including personally identifiable information belonging to guests, employees, and vendors. The threat of public data release formed the second half of ALPHV’s double-extortion strategy, maintaining confidentiality pressure even after systems were restored.

Integrity was compromised through the unauthorized modification of MGM’s identity infrastructure. By gaining administrator control of Okta and Azure Active Directory, the attackers could create, alter, and impersonate accounts — corrupting the integrity of the authentication system that the entire organization depended upon.

Availability was the most visibly destroyed pillar. The encryption of over one hundred ESXi hypervisors hosting thousands of virtual machines rendered MGM’s core operational systems — reservations, gaming, payments, room access — completely unavailable for ten days, directly harming guests and generating tens of millions of dollars in lost revenue.

CIA pillar	What was affected	Concrete MGM example
Confidentiality	Sensitive customer and organizational data secrecy	Claimed exfiltration of 6 TB of customer information, followed by threat of public release in extortion pressure
Integrity	Trustworthiness of identity and account-control systems	Unauthorized admin control over Okta and Azure AD enabled account manipulation and impersonation capability
Availability	Continuous access to critical business services	Encryption of 100+ ESXi hosts disrupted reservations, gaming, payments, room access, and mobile services for roughly ten days

Table 4: CIA triad mapping for the MGM Resorts incident

6.8 Defensive Lessons

The MGM attack exposes failures at multiple layers of what Section 7 of this report describes as Defense in Depth. Each layer that should have stopped or slowed the attack either did not exist or was insufficient.

The help desk had no caller verification protocol. The single most important lesson from this attack is that a ten-minute phone call should never produce administrator credentials. Secure service desk practices require callers to authenticate with something they have — a registered device, a hardware token, a one-time code — not only something they know, such as their name and job title. An attacker with LinkedIn access knows everything that knowledge-based verification checks for.

Multi-factor authentication on privileged accounts was weak. The attackers capitalized on weak multi-factor authentication to escalate privileges and gain control of the Azure Active Directory domain controller. Brown & Brown MFA on administrative accounts must be phishing-resistant — hardware security keys or certificate-based authentication — not SMS or app-push approvals, both of which are vulnerable to social engineering.

The network lacked segmentation between identity and operations. The critical failure that converted a digital breach into a physical operational crisis was the pathway from cloud identity management to on-premise ESXi infrastructure. A properly segmented network with strict boundaries between the identity management layer, corporate IT, and operational technology would have contained the blast radius significantly.

Backups did not protect against the double-extortion model. MGM's ability to restore systems after ten days demonstrates that backup capabilities existed. However, restoring data from backup does nothing to address the 6 TB of already-exfiltrated customer records. The triple-extortion model described in Chapter 8 of this report — encryption, data theft, and harassment — renders traditional backup-as-defense incomplete.

User awareness training must explicitly address vishing. The IT help desk staff who granted credentials were not acting maliciously or carelessly by their own training standards — they were following normal helpdesk procedures. User awareness programs must include specific scenarios for voice-based impersonation attacks, with clear protocols that override normal helpfulness instincts when administrative access is at stake.

7 Defense strategies and Risk mitigation

7.1 Overview of Defense Strategies

In the context where malicious software (malware) is increasingly growing in sophistication and evasion capability, relying solely on a single security solution has become outdated and insufficient to withstand threats. Modern organizations are required to implement a “Defense-in-Depth” strategy – establishing a comprehensive multi-layered protection framework to address cybersecurity risks [3].

The core objectives of this defense strategy are built upon three main operational pillars:

- **Prevention (Prevent):** Stop intrusion attempts from outside right at the first barriers.
- **Detection (Detect):** Early and accurate identification of attack signs or abnormal behaviors within the system.
- **Mitigation (Mitigate):** Isolate risks, minimize damage, and quickly restore operations when a security incident occurs.

To realize these three pillars, a complete defense strategy requires the coordinated integration of multiple protection layers. Among them, User Authentication plays the role of a foundational building block and the first line of defense, enabling access control, ensuring traceability, and protecting data integrity.

However, strong authentication is only the starting point. To make the system truly resilient against all attack scenarios, organizations must combine authentication with other risk management pillars, including: continuously reducing vulnerabilities through Patch Management, ensuring availability through Backup Strategy, proactively responding through Incident Response processes, and finally strengthening the weakest link through User Awareness enhancement. The combination of all these factors determines the survivability of a modern information system.

7.2 Defense-in-Depth Model

7.2.1 Concept of Defense-in-Depth

Defense-in-Depth is a cybersecurity strategy and architecture model designed based on the principle of establishing multiple independent and sequential protection layers. The core philosophy of this model is the acknowledgment that no single security control is perfect. By stacking multiple defense layers, if a malicious actor (malware) or hacker bypasses one layer, the subsequent layers will continue to operate to block, slow down the intrusion process, and protect system assets.

Typical technical defense layers in this model include:

- **Network/Perimeter Layer:** Acts as the outermost defensive boundary, using Firewalls and Intrusion Detection/Prevention Systems (IDS/IPS) to control, filter, and monitor all incoming and outgoing network traffic.

- **Endpoint Layer:** Provides direct protection at user-facing devices (workstations, mobile devices, servers) through Antivirus software and Endpoint Detection and Response (EDR).
- **Application Layer:** Prevents exploitation of software vulnerabilities by applying Secure Coding practices from the development stage and using Web Application Firewalls (WAF).
- **Data Layer:** The most critical core layer, protecting data confidentiality through strong Encryption mechanisms and strict Access Control policies.

7.2.2 Integration of the AAA Access Control Framework

To ensure that defense layers from network to data operate consistently and tightly, organizations need to implement a unified control mechanism called the AAA framework (Authentication, Authorization, Accounting) [4].

The AAA framework governs the entire lifecycle of an entity’s access to the system:

- **Authentication (Authentication - Identity Check):** This is the mandatory starting point of the AAA framework. It acts as a “gatekeeper”, answering the question: “Is this user or device truly the identity they claim to be?”. If this identity verification step is not passed, the subject will be denied access immediately at the outer layer and cannot proceed deeper into application or data layers.
- **Authorization (Authorization - Permissions):** After the system successfully verifies identity in the Authentication step, the Authorization process takes place. This step strictly applies the Principle of Least Privilege, meaning only granting users the minimum permissions necessary to perform their tasks.
- **Accounting (Accounting/Logs):** The final step is to monitor and record all user actions after login. All actions such as opening files, downloading, or modifying data are stored in system logs. This creates non-repudiation and serves as important data for incident investigation.

7.3 Enhancing Access Control and User Authentication

7.3.1 Role of Authentication in Preventing Attacks

User Authentication is the main defensive shield (main shield) against attackers attempting to take over system accounts. In the context of malware distribution campaigns often accompanied by credential theft, a strong authentication mechanism will neutralize the attacker’s ability to perform masquerade attacks on legitimate users, even if they have obtained part of the information.

7.3.2 Weaknesses of Single-Factor Authentication (SFA) and Common Attack Methods

Single-Factor Authentication (SFA), usually based only on passwords (“something you know”), is currently considered very weak and vulnerable. Attackers can easily bypass SFA through the following methods:

- **Brute Force & Dictionary Attacks:** Attackers use automated tools to try thousands of password combinations or use lists of commonly used/leaked passwords. The RockYou data breach (2009) with more than 32 million exposed passwords is evidence of the danger of weak password practices and password reuse.
- **Rainbow Table Attacks:** Exploit insecure password storage systems (hashed passwords without salting) to reverse back to the original passwords, typically the Adobe breach (2013) with 150 million compromised accounts.

7.3.3 Levels of Upgrading Authentication Strategy

To defend effectively, organizations must upgrade authentication systems based on the combination of multiple independent factors:

- **Two-Factor Authentication (2FA) and Multi-Factor Authentication (MFA):** Require users to provide at least one additional verification factor beyond a password, such as “Something you have” (OTP via phone, hardware token) or “Something you are” (Biometrics: fingerprint, face).

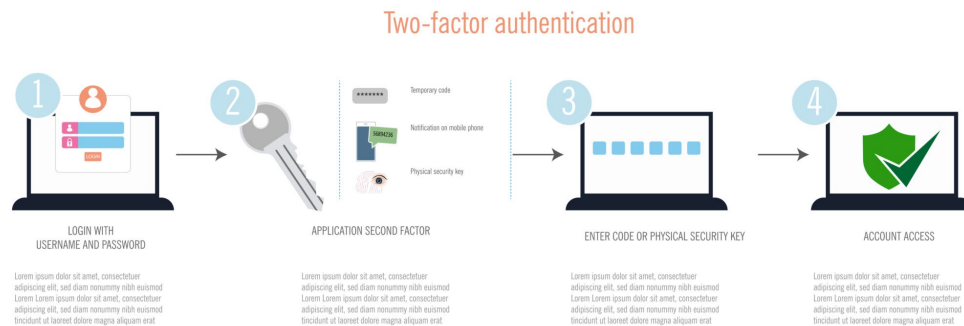


Figure 4: Security reports indicate that implementing MFA can prevent more than 99% of automated account takeover attacks [1].

- **Passwordless Authentication (Passwordless & Passkeys):** This is the most advanced defense technology trend today, based on WebAuthn and FIDO standards. Instead of sharing passwords (shared secrets), Passkeys use cryptographic key pairs stored directly on the device. This method not only optimizes user experience but also completely eliminates risks such as phishing-resistant attacks and credential stuffing [5].

7.3.4 Real-world Case Study: Security Transformation at Google

To cope with the massive scale of online fraud, Google implemented a historic authentication transformation strategy:

- **Phase 1:** Mandatory application of MFA for high-risk accounts (such as administrators) and expansion to general users, combined with push-based authentication to improve usability.

- **Phase 2:** Pioneered global-scale Passkey deployment. This process helped Google significantly reduce operational costs (related to password reset support and account recovery) and protect billions of users from the most sophisticated phishing techniques.

7.4 Patch Management Process and Risk Reduction

7.4.1 Concept and Importance of Patch Management

Patch Management is not simply pressing the “update” button on software; it is a systematic strategic process aimed at fixing security vulnerabilities before they are exploited by attackers [3].

In information security, there exists a concept called the “Vulnerability Window” – this is the period from when a software vulnerability is disclosed until the system is actually patched to fix that vulnerability. Delays, postponement, or ignoring the update process are the root cause that create conditions for malware to spread and cause cyberattacks on a large scale.

7.4.2 Standard Patch Management Process

To ensure the system is not disrupted due to compatibility issues of new updates while still closing vulnerabilities, a professional patch management process in enterprises will go through the following steps:

- **Discovery & Assessment:** Continuously monitor security bulletins to detect new vulnerabilities. Evaluate the severity of vulnerabilities for the current system.
- **Testing:** Never deploy patches directly to the entire production system. Updates must be installed in a simulated environment (Sandbox/Test environment) to ensure they do not conflict with existing business applications.
- **Deployment:** Schedule official updates, prioritizing servers/devices storing important data first.
- **Verification & Monitoring:** Re-check to ensure the patch has been successfully applied and the system operates stably.

7.4.3 Real-world Case Study: WannaCry Ransomware Disaster

The WannaCry ransomware outbreak in May 2017 is the most valuable evidence of weaknesses in patch management processes of organizations worldwide [6].

- **Vulnerability Context:** WannaCry malware was designed to automatically spread through internal networks by exploiting a critical vulnerability in the Windows SMB protocol (identifier CVE-2017-0144, also known as EternalBlue).
- **Deadly Delay:** In fact, Microsoft released a patch for this vulnerability in March 2017. However, many government agencies, hospitals, and large corporations did not perform updates in time.
- **Consequences:** More than 200,000 computers in over 150 countries were infected, all data was encrypted and ransom demanded, paralyzing healthcare and transportation

systems in many countries. If the patch management process had been strictly implemented immediately when Microsoft released the update, this entire disaster could have been completely prevented from the beginning.

7.5 Data Backup Strategy and the 3-2-1 Rule

7.5.1 Importance of Backup in Security

Data backup is considered the “last survival shield” when outer technical defense layers fail before disasters, especially destructive attacks from ransomware. Considering under the core security model CIA Triad (CIA Triad), backup strategy plays a decisive role in protecting Availability, ensuring systems and business services can operate again in the shortest time after incidents.

7.5.2 Gold Standard: The 3-2-1 Backup Rule

To ensure the highest resilience against data loss risks, organizations are recommended to strictly follow the 3-2-1 rule:

- **3 copies of data:** Always maintain at least three copies of important data (including 1 original copy in operation and 2 independent backup copies). Having multiple copies helps minimize the risk of total loss if one copy is corrupted or infected.
- **2 different storage media types:** Store backup copies on at least two different physical technologies or storage systems (for example: NAS and tape). This helps avoid mass hardware failure risks.
- **1 offsite backup:** It is mandatory to have at least one backup located outside the main data center (for example: Cloud or another geographic location). This is the most important protection layer against physical disasters or large-scale malware spread.

7.5.3 Enhanced Defense: Immutable and Air-gapped Backup

In the context of increasingly sophisticated ransomware, they not only encrypt original data but also attempt to delete backup copies connected to the system. Therefore, backup strategies must be upgraded with the following technologies:

- **Immutable Backup:** Data is stored using the WORM (Write Once, Read Many) mechanism, cannot be modified or deleted within a defined period, even by administrators.
- **Air-gap:** Backup copies are completely isolated from internal networks and the Internet, only temporarily connected during backup execution.

7.5.4 Core Benefits and Practical Application

Implementing a proper backup strategy brings essential benefits:

- Fast and accurate data recovery.
- Neutralizing pressure from ransomware attacks.
- Ensuring business continuity.

Real-world example: An enterprise is attacked by ransomware causing all data to be encrypted. Thanks to applying the 3-2-1 rule with backup copies on Cloud, the IT team isolated the system, restored data from a clean backup copy and brought the system back to operation within only a few hours without paying ransom.

7.6 Incident Response Lifecycle

7.6.1 Importance of Incident Response

No matter how well an organization deploys Defense-in-Depth architecture, the risk of intrusion always exists. When an incident occurs (for example: a server is infected with malware, an administrator account is stolen), time is the core factor. A standardized Incident Response (IR) process will help the organization move from a “passive, panicked” state to a “proactive controlled” state, with the goal: early detection of incidents, minimizing impact as much as possible, and restoring systems quickly.

7.6.2 Six Phases of the Incident Response Lifecycle

A complete incident response lifecycle includes six phases:

- **Preparation:** Establish a CSIRT team, build response playbooks, deploy monitoring tools and ensure backup systems are operational.
- **Detection:** Use SIEM or log systems to detect abnormal signs (for example: multiple failed login attempts or sudden increase in encrypted traffic).
- **Containment:** Isolate infected devices, segment the network and lock suspicious accounts to prevent malware from spreading.
- **Eradication:** Remove malware, delete backdoors and patch exploited vulnerabilities.
- **Recovery:** Restore systems from clean backup copies and monitor to ensure no reinfection occurs.
- **Lesson Learned:** Analyze root causes and upgrade the system (for example: transition from SFA to MFA).

7.6.3 Real-world Example (Ransomware Response Scenario)

An employee is tricked into downloading malware from a phishing email:

- The EDR system detects abnormal encryption processes (Detection).
- The computer is isolated from the internal network (Containment).
- The IT team removes malware and cleans the system (Eradication).
- Data is restored from Cloud backup (Recovery).
- The company organizes anti-phishing training and upgrades authentication (Lesson Learned).

7.7 User Awareness and Security Recommendations

7.7.1 Humans: The Weakest Link

In any information system, no matter how perfectly Defense-in-Depth architecture is designed, humans are always considered the “weakest link” in the security chain. Instead of directly attacking technical systems, attackers often use Social Engineering techniques to manipulate users [2].

7.7.2 Common Risky Behaviors

Common mistakes that users often make include:

- **Phishing:** Clicking on fraudulent links leading to credential theft or malware installation.
- **Downloading Malicious Software:** Installing cracked software or from untrusted sources.
- **Weak Passwords:** Using easily guessable passwords or reusing passwords.
- **Ignoring Updates:** Not updating systems, creating vulnerabilities for hackers to exploit.

7.7.3 Recommendations and Solutions

For End Users:

- Use strong passwords and enable MFA.
- Participate in periodic security awareness training.

For Technical Departments:

- Deploy SIEM, EDR for monitoring.
- Apply Network Segmentation.

7.8 Future Trends and Conclusion

7.8.1 Emerging Cybersecurity Threats

Modern attack trends include:

- **AI-powered Malware:** Using AI to create sophisticated malware and phishing.
- **Fileless & Living-off-the-Land:** Attacks without files, using system tools such as PowerShell.
- **Ransomware 3.0 & Supply Chain Attack:** Attacks through supply chains (example SolarWinds).

7.8.2 Overall Conclusion

Cybersecurity threats are increasingly sophisticated and dangerous. Protecting systems cannot rely on a single solution.

To ensure the three core elements of information security:

- Confidentiality
- Integrity
- Availability

Organizations need to:

- Deploy multi-layered defense (Defense-in-Depth)
- Upgrade authentication (MFA, Passkey)
- Build operational and incident response processes
- Enhance user awareness

8 Future Trends in Malicious Software

As digital transformation accelerates, malicious software is evolving from static, fixed-rule programs into intelligent, stealthy, and adaptive digital weapons. Based on current developments in the cybersecurity landscape, the following five trends represent the next generation of malware threats:

8.1 AI-Powered and Autonomous Malware

- **Definition:** This refers to malware that integrates Artificial Intelligence (AI) and Machine Learning (ML) to automate decision-making processes that previously required human intervention.
- **The Mechanism:** Unlike traditional malware that follows a hard-coded path, AI-powered malware can perform "Automated Reconnaissance." It analyzes the victim's security environment, identifies specific firewall rules or antivirus signatures, and then modifies its own code (Advanced Polymorphism) to bypass those defenses.
- **The Threat:** AI enables malware to stay dormant until the most opportune moment. Furthermore, AI-driven Deepfakes (cloning voices or faces) will make Social Engineering almost impossible to detect, as employees can no longer trust their eyes or ears during video calls [45, 46].

8.2 Fileless Malware and "Living-off-the-Land" (LotL)

- **Definition:** A sophisticated technique where the malicious code resides entirely in the computer's volatile memory (RAM) instead of being saved as a file on the hard drive.
- **The Mechanism:** Most antivirus software works by scanning files on the disk for known "bad signatures." Fileless malware avoids this by exploiting the "trust" of the Operating System. It uses legitimate system administrative tools, such as PowerShell or Windows Management Instrumentation (WMI), to execute malicious commands directly in memory.
- **The Threat:** Because the attacker is using "authorized" tools already found on the victim's computer, this is called "Living-off-the-Land." Since no "infected file" is ever created, it leaves almost no digital footprint, making it one of the most difficult types of malware to detect and remove [47].

8.3 IoT Botnets and Critical Infrastructure Threats

- **Definition:** The large-scale infection of "Internet of Things" (IoT) devices—ranging from smart cameras and thermostats to industrial sensors—to build massive, distributed zombie networks.
- **The Mechanism:** Billions of IoT devices are shipped with weak security frameworks and default passwords that are rarely changed. Malware like the Mozi or Mirai variants can scan the entire IPv4 address space in hours, infecting vulnerable devices and turning them into "bots" waiting for a command [1].
- **The Threat:** While one smart device is weak, a Botnet of millions of devices can launch a Distributed Denial of Service (DDoS) attack powerful enough to disable national

power grids, banking systems, or healthcare networks, shifting the threat from digital inconvenience to physical safety risks.

8.4 Ransomware 3.0: The Triple Extortion Model

- Definition: An advanced evolution of ransomware that applies three distinct layers of psychological and financial pressure to ensure the victim pays the ransom.
- The Mechanism: This trend moves beyond simple data encryption:
 1. Encryption: Locking the victim's data to stop operations (Availability loss).
 2. Exfiltration (Data Theft): Stealing sensitive records and threatening to leak them online (Confidentiality loss).
 3. Harassment: Directly contacting the company's clients, partners, or employees to inform them of the breach and pressure the organization from all sides.
- The Threat: This model makes backups (the traditional defense) ineffective. Even if an organization can restore its data from a backup, it cannot "un-leak" a secret or repair the ruined reputation caused by public data disclosure [45].

8.5 Supply Chain Attacks (Software Poisoning)

- Definition: A strategic attack where malware is injected into a trusted software vendor's product or update mechanism to reach thousands of downstream customers at once.
- The Mechanism: Instead of attacking a well-defended target (like a bank), hackers compromise a software provider that the target trusts. They hide a backdoor inside a legitimate software update.
- The Threat: When the customer clicks "Update Now" for a trusted app, they are unknowingly installing malware with administrative privileges. Because the update is "signed" and comes from a "trusted" source, the system's defenses are completely bypassed. A single supply chain compromise, such as the SolarWinds incident, can cause a mass-infection event globally [46].

9 Conclusion

The study of Chapter 8 shows that malicious software has changed from a small technical problem into a professional criminal tool. As malware becomes smarter, our ways of defending must also improve.

9.1 Final Summary of Key Lessons

Through our research, we can conclude three main things:

- Technology is not the only answer: We can have the best firewalls, but Social Engineering (tricking people) is still the easiest way for hackers to get in. Educating users (User Awareness) is the most important layer of defense [1].
- Protecting the CIA Triad: Every attack we studied targets the pillars of security. Spyware breaks Confidentiality, Viruses break Integrity, and Ransomware destroys Availability. A good security plan must protect all three [1].
- Focus on Resilience: Since threats like "Fileless" and "AI malware" are hard to stop, organizations must focus on Cyber Resilience. This means being ready to recover quickly using a strong 3-2-1 Backup Strategy and a clear Incident Response plan.

9.2 The Reality in Vietnam

The 2024-2025 Ransomware attacks in Vietnam, which hit companies like VNDIRECT and PVOIL, prove that the theories in Chapter 8 are very real. These attacks caused huge losses and showed that Vietnamese businesses must implement Defense in Depth immediately to survive in the digital age.

9.3 Final Words

Malware will never stop evolving. However, by staying proactive with Patch Management, using modern AI-based defense tools, and constantly teaching users to be careful, we can stay safe. Security is not a one-time job; it is a continuous journey of learning and adapting.

References

- [1] Microsoft Security. One simple action you can take to prevent 99.9 percent of attacks on your accounts. <https://www.microsoft.com/en-us/security/blog/2019/08/15/one-simple-action-you-can-take-to-prevent-99-9-percent-of-attacks/>, 2019.
- [2] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 4th edition, 2018.
- [3] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 4th edition, 2018.
- [4] National Institute of Standards and Technology (NIST). Security and privacy controls for information systems and organizations. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>, 2020. NIST Special Publication 800-53 Rev. 5.
- [5] FIDO Alliance. How passkeys work. <https://fidoalliance.org/passkeys/>, 2023.
- [6] Microsoft. Microsoft security bulletin ms17-010 - critical. <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>, 2017.
- [7] National Audit Office (UK). Wannacry ransomware cyber attack. Technical report, National Audit Office, 2017. Public sector cyber incident report.
- [8] The Hill. Hillicon valley — apache vulnerability sets off alarm bells. <https://thehill.com/policy/technology/overnights/585832-hillicon-valley/>, 2021.
- [9] The Guardian. Ddos attack that disrupted internet was largest of its kind in history, experts say. <https://www.theguardian.com/technology/2016/oct/26/ddos-attack-dyn-mirai-botnet>, 2016.
- [10] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, 4th edition, 2021. Chapter 8: Malicious Software and Attack Vectors.
- [11] Taipei Times. Vietnamese hacker becomes cyberagent. <https://www.taipeitimes.com/News/world/archives/2022/05/26/2003778844>, 2022.
- [12] Ministry of Science and Technology Vietnam. Hieu pc: From hacker to cybersecurity expert. <https://mst.gov.vn/hieu-pc-tu-mot-hacker-gioi-nhat-the-gioi-den-chuyen-gia-ve-an-ninh-mang-197152090.htm>, 2021.
- [13] The Guardian. Lulzsec: what they did, who they were and how they were caught. <https://www.theguardian.com/technology/2013/may/16/lulzsec-hacking-fbi-jail>, 2013.
- [14] BBC News. George floyd: Anonymous hackers re-emerge amid us unrest. <https://www.bbc.co.uk/news/technology-52879000>, 2020.
- [15] EBSCO Research Starters. Anonymous. <https://www.ebsco.com/research-starters/biography/anonymous>, 2024.

- [16] Control Engineering. Throwback attack: An insider releases 265,000 gallons of sewage on the maroochy shire. <https://www.controleng.com/throwback-attack-an-insider-releases-265000-gallons-of-sewage-on-the-maroochy-shire>, 2021.
- [17] EBSCO Research Starters. Stuxnet. <https://www.ebsco.com/research-starters/computer-science/stuxnet>, 2024.
- [18] Dan Tri. The world’s first terrifying digital weapon. <https://dantri.com.vn/cong-nghe/stuxnet-vu-khi-ky-thuat-so-dang-so-dau-tien-tren-the-gioi-202409210526244.htm>, 2024.
- [19] Reuters. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://www.reuters.com/legal/government/ex-google-engineer-convicted-stealing-ai-secrets-chinese-companies-2026-01-29/>, 2026.
- [20] VNExpress. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://e.vnexpress.net/news/tech/tech-news/ex-google-engineer-convicted-of-stealing-ai-secrets-for-chinese-companies-5011854.html>, 2026.
- [21] A.W. Junaid. Mafiaboy’s moment: The 2000 denial-of-service attacks that shook the internet. <https://awjunaid.com/cyber-security/mafiaboys-moment-the-2000-denial-of-service-attacks-that-shook-the-internet/>, 2025.
- [22] Fortinet. Solarwinds cyber attack: An overview. <https://www.fortinet.com/uk/resources/cyberglossary/solarwinds-cyber-attack>.
- [23] TechTarget. Solarwinds hack explained: Everything you need to know. <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>, 2023.
- [24] UK National Cyber Security Centre. Moveit vulnerability and data extortion incident. <https://www.ncsc.gov.uk/information/moveit-vulnerability>, 2023.
- [25] National Audit Office (UK). Wannacry ransomware cyber attack. Technical report, National Audit Office, 2017. Public sector cyber incident report.
- [26] Cloudflare. What is wannacry ransomware? <https://www.cloudflare.com/learning/security/ransomware/wannacry-ransomware/>.
- [27] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 3rd edition, 2018. Chapter 8: Malicious Software and Attack Vectors.
- [28] Swiss Cyber Institute. Top 12 worst computer viruses in history (& what they taught us about cybersecurity), 2025. Accessed March 22, 2026.
- [29] Mikalai Shershan. Twilio data breach: what happened and how to protect yourself. <https://onerep.com/blog/twilio-data-breach-how-to-protect-yourself>, 2025.
- [30] Europol. World’s most dangerous malware emotet disrupted through global action. <https://www.europol.europa.eu/media-press/newsroom/news/world%E2%80%99s-most-dangerous-malware-emotet-disrupted-through-global-action>, 2021.
- [31] IBM. What is the log4j vulnerability? <https://www.ibm.com/think/topics/log4j>.

- [32] Rebecca Klar Miller and Chris Mills Rodrigo. Hillicon valley — apache vulnerability sets off alarm bells. <https://thehill.com/policy/technology/overnights/585832-hillicon-valley/>, 2021.
- [33] The Guardian. Ddos attack that disrupted internet was largest of its kind in history, experts say. <https://www.theguardian.com/technology/2016/oct/26/ddos-attack-dyn-mirai-botnet>, 2016.
- [34] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, 4th edition, 2021. Chapter 8: Malicious Software and Attack Vectors.
- [35] Taipei Times. Vietnamese hacker becomes cyberagent. <https://www.taipeitimes.com/News/world/archives/2022/05/26/2003778844>, 2022.
- [36] Ministry of Science and Technology Vietnam. Hieu pc: From hacker to cybersecurity expert. <https://mst.gov.vn/hieu-pc-tu-mot-hacker-gioi-nhat-the-gioi-den-chuyen-gia-ve-an-ninh-mang-197152090.htm>, 2021.
- [37] The Guardian. Lulzsec: what they did, who they were and how they were caught. <https://www.theguardian.com/technology/2013/may/16/lulzsec-hacking-fbi-jail>, 2013.
- [38] BBC News. George floyd: Anonymous hackers re-emerge amid us unrest. <https://www.bbc.co.uk/news/technology-52879000>, 2020.
- [39] EBSCO Research Starters. Anonymous. <https://www.ebsco.com/research-starters/biography/anonymous>, 2024.
- [40] Control Engineering. Throwback attack: An insider releases 265,000 gallons of sewage on the maroochy shire. <https://www.controleng.com/throwback-attack-an-insider-releases-265000-gallons-of-sewage-on-the-maroochy-shire>, 2021.
- [41] EBSCO Research Starters. Stuxnet. <https://www.ebsco.com/research-starters/computer-science/stuxnet>, 2024.
- [42] Dan Tri. The world’s first terrifying digital weapon. <https://dantri.com.vn/cong-nghes/stuxnet-vu-khi-ky-thuat-so-dang-so-dau-tien-tren-the-gioi-202409210526244.htm>, 2024.
- [43] Reuters. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://www.reuters.com/legal/government/ex-google-engineer-convicted-stealing-ai-secrets-chinese-companies-2026-01-29/>, 2026.
- [44] VNExpress. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://e.vnexpress.net/news/tech/tech-news/ex-google-engineer-convicted-of-stealing-ai-secrets-for-chinese-companies-5011854.html>, 2026.
- [45] A.W. Junaid. Mafiaboy’s moment: The 2000 denial-of-service attacks that shook the internet. <https://awjunaid.com/cyber-security/mafiaboys-moment-the-2000-denial-of-service-attacks-that-shook-the-internet/>, 2025.
- [46] Fortinet. Solarwinds cyber attack: An overview. <https://www.fortinet.com/uk/resources/cyberglossary/solarwinds-cyber-attack>.

- [47] TechTarget. Solarwinds hack explained: Everything you need to know. <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>, 2023.
- [48] UK National Cyber Security Centre. Moveit vulnerability and data extortion incident. <https://www.ncsc.gov.uk/information/moveit-vulnerability>, 2023.
- [49] National Audit Office (UK). Wannacry ransomware cyber attack. Technical report, National Audit Office, 2017. Public sector cyber incident report.
- [50] Cloudflare. What is wannacry ransomware? <https://www.cloudflare.com/learning/security/ransomware/wannacry-ransomware/>.
- [51] Federal Bureau of Investigation. A study on the morris worm. https://www.researchgate.net/publication/337499010_A_study_on_the_Morris_Worm. Akshay Jajoo; historical analysis of the 1988 incident.
- [52] Huntress. Iloveyou malware: Analysis, detection, removal. <https://www.huntress.com/threat-library/malware/iloveyou>, 2024.
- [53] EBSCO Research Starters. Iloveyou virus attacks computers. <https://www.ebsco.com/research-starters/computer-science/iloveyou-virus-attacks-computers>.
- [54] Computerworld Staff. ‘love bug’ virus charges reportedly dropped, 2000. Computerworld; accessed February 3, 2026.
- [55] Respicio & Co. Law Firm. The emergence and significance of ra 8792: A comprehensive legal overview. <https://www.respicio.ph/dear-attorney/the-emergence-and-significance-of-ra-8792-a-comprehensive-legal-overview>, 2024. Accessed February 3, 2026.
- [56] The Record. Cyberattack on vietnam securities broker disrupts stock markets. <https://therecord.media/vietnam-securities-broker-cyberattack-vndirect>, 2024.
- [57] Sangfor Technologies. The top ransomware attacks in 2024. <https://www.sangfor.com/blog/cybersecurity/ransomware-attacks-2024-top-ransomware-headlines>, 2024.
- [58] Dark Reading. Ransomware, junk bank accounts: Cyber threats proliferate in vietnam. <https://www.darkreading.com/cyber-risk/ransomware-junk-bank-accounts-cyberthreats-proliferates-in-vietnam>, 2024.
- [59] The Investor. Gasoline retailer pvoil hit by ransomware attack. <https://theinvestor.vn/gasoline-retailer-pvoil-hit-by-ransomware-attack-d9363.html>, 2024.
- [60] Vietbao.vn. Pvoil was subjected to a data encryption attack, causing system downtime. <https://vietbao.vn/en/pvoil-bi-tan-cong-ma-hoa-du-lieu-he-thong-ngung-tre-479453.html>, 2024.
- [61] VNCS. Why can the pvoil system recover quickly after a ransomware attack? <https://vncs.vn/en/tin-tuc/detail-why-can-the-pvoil-system-recover-quickly-after-a-ransomware-attack-341>, 2024.

- [62] Trend Micro. Ransomware spotlight: Blackcat. <https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-blackcat>, 2024.
- [63] Varonis. Blackcat ransomware (alphv). <https://www.varonis.com/blog/blackcat-ransomware>, 2024.
- [64] PVOIL. Press release regarding the restoration of pvoil’s information technology system. <https://pvoil.com.vn/en/press-release-regarding-the-restoration-of-pvoils-information-technology-system>, 2024.
- [65] VNCS. Breaking news: Another large enterprise in vietnam was attacked by ransomware. <https://vncs.vn/en/tin-tuc/detail-breaking-news-another-large-enterprise-in-vietnam-was-attacked-by-ransomware>, 2024.
- [66] The Record. Vietnam’s state postal service claims to restore its systems after cyberattack. <https://therecord.media/vietnam-claims-restore-services-cyberattack>, 2024.
- [67] Ministry of Information and Communications. Vietnam sees sharp decline in cyber attacks as awareness of security rises. <https://beta-en.mic.gov.vn/vietnam-sees-sharp-decline-in-cyber-attacks-as-awareness-of-security-rises-19724111.htm>, 2024.
- [68] Viettel Cyber Security. Viettel releases 2024 vietnam cybersecurity threat landscape report. <https://viettel.com.vn/en/news-events/news/viettel-releases-2024-vietnam-cybersecurity-threat-landscape-report/>, 2024.
- [69] Bkav Corporation. 60% of vietnamese businesses are not equipped with adequate security solutions. <https://www.bkav.com/top-new/-/view-content/2327397/60-of-vietnamese-businesses-are-not-equipped-with-adequate-security-solutions>, 2024.
- [70] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 4th edition, 2018.
- [71] IBM Security. Cost of a data breach report 2024: Ai and automation in cybersecurity. Technical report, 2024.
- [72] Murugiah Souppaya and Karen Scarfone. Guide to malware incident prevention and handling for desktops and laptops. Technical Report SP 800-83 Rev. 1, National Institute of Standards and Technology (NIST), 2023.
- [73] CrowdStrike. 2024 global threat report: Cyberattacks in the age of ai. Technical report, 2024.
- [74] Ministry of Information and Communications. Enhancing network security critical to defend against attacks. <https://english.mic.gov.vn/enhancing-network-security-critical-to-defend-against-attacks-19724042309573251.htm>, 2024.
- [75] Vietnam News. Ransomware attack hits vietnam post. <https://vietnamnews.vn/economy/1656859/ransomware-attack-hits-vietnam-post.html>, 2024.

- [76] The Investor. Vietnam postal services crippled by ransomware attack. <https://theinvestor.vn/vietnam-postal-services-crippled-by-ransomware-attack-d10489.html>, 2024.
- [77] VietNamNet. Cmc group hit by ransomware attack, authorities launch investigation. <https://vietnamnet.vn/en/cmc-group-hit-by-ransomware-attack-authorities-launch-investigation-2391420.html>, 2024.
- [78] Ministry of Information and Communications. Lockbit, blackcat, and stealer malware among top threats in vietnam q3 2024. <https://beta-en.mic.gov.vn/lockbit-blackcat-and-stealer-malware-among-top-threats-in-vietnam-q3-2024-197241104.htm>, 2024.
- [79] VietNamNet. Vndirect cyberattack causes big splash on stock market. <https://vietnamnet.vn/en/vndirect-cyberattack-causes-big-splash-on-stock-market-2264185.html>, 2024.
- [80] Palo Alto Networks Unit 42. Ransomware retrospective 2024: Unit 42 leak site analysis. <https://unit42.paloaltonetworks.com/unit-42-ransomware-leak-site-data-analysis-all-2023/>, 2024.
- [81] CISA. Understanding ransomware threat actors: Lockbit. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a>, 2023.
- [82] Group-IB. Deciphering the brain cipher ransomware. <https://www.group-ib.com/blog/brain-cipher-ransomware/>, 2024.
- [83] Netskope. Blackcat ransomware: Tactics and techniques from a targeted attack. <https://www.netskope.com/blog/blackcat-ransomware-tactics-and-techniques-from-a-targeted-attack>, 2024.
- [84] Viettel Cyber Security. Viettel releases cybersecurity report for the first half of 2024. <https://viettel.com.vn/en/news-events/news/viettel-releases-cybersecurity-report-for-the-first-half-of-2024/>, 2024.
- [85] Stav Cohen et al. Here comes the ai worm: Unleashing zero-click worms that target genai-powered applications. <https://arxiv.org/html/2403.02817v2>, 2024.
- [86] IBM Security. Cost of a data breach report 2024. Technical report, 2024.
- [87] Gartner. Top strategic cybersecurity trends for 2024–2025. Technical report, 2024.
- [88] Paul Cichonski, Tom Millar, Tim Grance, and Karen Scarfone. Computer security incident handling guide. Technical Report SP 800-61 Revision 2, National Institute of Standards and Technology, 2012.
- [89] Fortinet. History of cyber warfare and the top 5 most notorious attacks. <https://www.fortinet.com/resources/cyberglossary/most-notorious-attacks-in-the-history-of-cyber-warfare>, 2024.